

Protocole de pentest & autorisation de test

Projet fil rouge — Audit eRezo

À lire, comprendre et signer AVANT tout test sur la production. On ne pentest jamais une application sans cadre écrit — même la sienne. C'est la règle n°1 du métier (et la Compétence 7 du module).

1. Périmètre autorisé

Cible autorisée	https://erezo.fr uniquement
Type de test	Lecture seule / non destructif
Fenêtre de test	Uniquement pendant la séance en classe — aucun test hors séance
Compte de test fourni	communiqué par le formateur

Hors périmètre (interdit) : tout autre domaine ou sous-domaine, toute infrastructure tierce (hébergeur, CDN, services externes), tout compte autre que le compte de test fourni.

2. Règles impératives

✓ Autorisé

- Reconnaissance passive (DNS, en-têtes HTTP, robots.txt, sitemap, certificats)
- Navigation authentifiée avec le **compte de test fourni**
- Test manuel d'endpoints (modification d'ID, paramètres) en **lecture seule**
- Scans OWASP **non destructifs** et à débit raisonnable
- Analyse des en-têtes de sécurité, cookies, CSRF, configuration

🚫 Interdit

- Toute action **destructive** : suppression, modification massive, corruption de données
- Injection destructive** (DROP, DELETE, écriture de payloads persistants)
- Brute-force** de mots de passe / **déni de service (DoS)** / flood de requêtes
- Exfiltration ou stockage de données personnelles réelles** d'autres utilisateurs
- Attaque de l'infrastructure (serveur, hébergeur, CDN)
- Test **en dehors de la séance en classe** (aucun pentest à la maison)

3. Manipulation des données

- Si vous croisez des **données personnelles réelles** (noms, emails, photos...), vous ne les copiez pas, ne les stockez pas, ne les publiez pas.
- Dans le rapport, **anonymisez systématiquement** (ex : « utilisateur A », « [email masqué] »).
- Tout artefact créé pendant le test (compte, contact, conversation de test) doit être **noté puis signalé** au formateur pour nettoyage.

4. En cas de problème

Si vous provoquez un comportement inattendu (erreur serveur, indisponibilité, donnée modifiée par erreur) :

1. **Arrêtez immédiatement** le test.
2. **Prévenez le formateur** sans délai.

3. **Documentez** ce qui s'est passé (heure, action, effet observé).

Signaler une erreur honnêtement fait partie du professionnalisme — ça ne vous pénalise pas.

5. Déclaration d'autorisation et d'engagement

À recopier / compléter et signer par chaque membre du groupe.

Groupe : _____

Membres : _____

Nous, soussigné·e·s, déclarons :

- avoir lu et compris le présent protocole ;
- avoir reçu l'autorisation explicite d'auditer `https://erezo.fr` dans le cadre pédagogique de ce module ;
- nous engager à respecter strictement le périmètre et les règles ci-dessus ;
- assumer que tout test hors de ce cadre engage notre seule responsabilité.

Membre	Date	Signature
_____	_____	_____
_____	_____	_____
_____	_____	_____
_____	_____	_____

Autorisation accordée par (formateur) : Maxime Nicole — KodeSaaS

Date : _____ Signature : _____